IA Invent IA

REVISIÓN DE SEGURIDAD · 19 DE SEPTIEMBRE DE 2026 · ACTUALIZADA EL 10 DE OCTUBRE

Qué está bien, qué falta y qué pide una certificación.

Revisión integral hecha con datos reales: políticas y funciones de la base, buckets de fotos, MFA de las cuentas, librerías y cabeceras de la app, secretos en el repositorio y protección de la rama de producción. La base está bien protegida. Lo que falta para certificar no es tanto código como **controles y evidencia**: quién puede qué, cómo se prueba y dónde queda escrito.

inventiapp.cl · contacto@inventiapp.cl

ESTADO

BIEN	Verificado. Sirve como evidencia para un cuestionario de seguridad.
HECHO	Corregido el 19 de septiembre, después de la revisión.
CRÍTICO	Hueco real o requisito básico de cualquier certificación. Primero.
IMPORTANTE	Defensa que falta o control débil. No expone datos hoy, pero un escáner lo marca.
EVIDENCIA	No es técnico: política escrita, prueba hecha o documento del proveedor.

ÁMBITO

SEGURIDAD	Quién ve qué, y qué puede suplantarse o inyectarse.
DATOS	Pérdida, integridad, respaldo y retención de la información.
OPERACIÓN	Rutinas, revisiones y fechas que hay que cumplir.
DOCUMENTACIÓN	Políticas y registros que una auditoría pide ver.

CONTENIDO

01 Lo que ya está bien — pág. 2
02 Hallazgos: críticos e importantes — pág. 3-4
03 Qué pide una certificación — pág. 5
04 Orden propuesto — pág. 6

El mismo día se corrigieron 1 (en la app), 4, 5 y 8, y Joel cerró 2, 6, 7 y el DMARC de 10. Quedan la librería de Excel (3), el CAPTCHA (9) y la evidencia escrita; la exigencia de MFA pasó a ser un interruptor por empresa (10/10).

01 · LO QUE YA ESTÁ BIEN

Verificado el 19 de septiembre

Cada punto se comprobó contra la base o el repositorio, no contra lo que dice la documentación. Sirven tal cual como respuesta a un cuestionario de seguridad de un cliente.

Aislamiento entre empresas (RLS) — BIEN

Las 40 tablas tienen RLS activo y políticas. Cada empresa ve solo lo suyo; un usuario normal no ve nada ajeno en ninguna. Verificado con barrido completo en agosto y hoy.

Vistas y funciones — BIEN

Todas las vistas usan `security_invoker`. Las 17 funciones con privilegios elevados tienen `search_path` fijo y el rol anónimo no puede ejecutarlas. Tras cada migración se revisan el advisor y los parámetros inválidos.

Fotos privadas por empresa — BIEN

El bucket de fotos no es público; solo se sube, lee y actualiza dentro de la carpeta de la propia empresa, con URL firmadas temporales. Límite de 20 MB y solo imágenes.

Sin secretos en el repositorio — BIEN

La clave de servicio y la de Flow viven solo en variables de entorno de Supabase y en secretos de GitHub. En el código público va únicamente la clave anónima, que es pública por diseño. El archivo de respaldo está en `.gitignore`.

Cobros y registro — BIEN

Los avisos de Flow no se creen: la función consulta a Flow con firma HMAC antes de tocar una suscripción. El registro de empresas va por una función con permisos acotados.

Auditoría y trazabilidad — BIEN

Cada cambio en conteos, materiales, movimientos y documentos queda con antes, después, quién y cuándo. Correcciones y anulaciones exigen motivo y no borran nada.

Pruebas antes de publicar — BIEN

Cada PR corre pruebas unitarias, de esquema y de navegador real en CI. Ningún cambio se publica en rojo. Sentry avisa de errores en producción.

Correo y dominio — BIEN

SPF, DKIM y DMARC en cuarentena (19/09): un correo que suplante a inventiapp.cl va a spam. Remitente contacto@inventiapp.cl. Una sesión por cuenta, con caducidad.

Respaldo y recuperación — BIEN

Supabase guarda copias diarias siete días. Hay un script propio de respaldo completo (base, roles, fotos, funciones) y un runbook de recuperación. Falta ejecutarlo (ver evidencia).

Infraestructura — BIEN

Postgres 17.6 al día, región São Paulo, cifrado en reposo y en tránsito por Supabase. App servida por GitHub Pages solo por HTTPS. Sentry no recibe datos personales.

Cuestionario de seguridad publicado — HECHO

Las 197 respuestas del CAIQ v4 están en el registro público CSA STAR (Level 1, autoevaluación; no es una auditoría): `cloudsecurityalliance.org/star/registry/inventia`. Es lo que se le manda a un comprador en vez de un PDF. Vence al año: renovar antes del 20/09/2027.

02 · HALLAZGOS

Críticos: huecos reales o requisitos básicos

Los tres se resuelven en días, no en semanas. Ninguno expone datos de clientes hoy, pero los tres son lo primero que revisa un auditor.

1 Ninguna cuenta usa MFA, incluidos los tres administradores

HECHO A MEDIAS · SEGURIDAD

La app ya permitía activar el segundo factor, pero cero cuentas lo tenían. **Hecho (19/09):** la app avisaba a cada admin y tenía fijado un bloqueo para el 1 de diciembre de 2026. **Actualizado (10/10):** por decisión de InventIA, exigirla pasó a ser un interruptor por empresa en Configuraciones, apagado por defecto; sin él, la app no avisa ni bloquea. La MFA sigue disponible en cada cuenta.

Quién: cada empresa decide **Esfuerzo:** un minuto por cuenta

2 La rama de producción no está protegida

HECHO · OPERACIÓN

Cualquiera con acceso al repositorio podía subir directo a `main`, sin PR ni pruebas, y GitHub Pages lo publicaba al instante. **Hecho (19/09):** `main` solo acepta cambios por PR con las dos pruebas de CI en verde, sin subida directa ni reescritura de historia (verificado por API: `protected: true`). Las 40 ramas viejas se comprobaron una por una como ya fusionadas y quedaron listas para borrar desde la pestaña Branches de GitHub.

Verificado: un intento de fusión sin CI actualizado fue rechazado por la regla

3 La librería de Excel tiene vulnerabilidades conocidas

CRÍTICO · SEGURIDAD

La app carga xlsx 0.18.5 desde un CDN. Tiene dos CVE publicados (2023-30533 y 2024-22363, corregidos en 0.19.3 y 0.20.2, que el autor ya no publica en npm). Solo la usan administradores con sus propios archivos, así que el riesgo real es bajo, pero cualquier escáner la marca. Desde el 19/09 se sirve desde el repositorio (ya no desde el CDN), pero sigue siendo la 0.18.5: la versión corregida solo se distribuye desde cdn.sheetjs.com, que el entorno de desarrollo no alcanza. **Falta:** que Joel baje xlsx.full.min.js 0.20.3 de ahí y lo deje en app/lib; después se prueban las cargas de Excel.

Quién: Joel baja el archivo; desarrollo lo prueba **Esfuerzo:** 10 minutos más una sesión de pruebas

Importantes: defensas que faltan

4 Sin Content Security Policy ni integridad en los scripts externos

HECHO · SEGURIDAD

La app carga tres scripts desde CDN (lector de códigos, Excel y Sentry) sin hash de integridad. Si alguien compromete el CDN, ejecuta código dentro de tu app con la sesión del usuario. **Hecho (19/09, PR #469):** xlsx y html5-qrcode se sirven desde el repositorio (sin CDN, y disponibles sin señal), y la app lleva una CSP que solo permite scripts propios y de Sentry, conexiones a Supabase y Sentry, y nada de frames ni objetos.

Verificado: sin violaciones en Chromium y con las pruebas e2e completas

5 Políticas declaradas para "public" y permisos de tabla al rol anónimo

HECHO · SEGURIDAD

34 políticas RLS aplican a cualquier rol y el rol anónimo tiene permisos sobre 30 tablas. Hoy no filtra nada porque las funciones de empresa devuelven vacío sin sesión, pero es defensa por accidente. **Hecho (19/09):** las 33 políticas pasaron a `authenticated`, el anónimo quedó solo con insertar leads, y las tablas que se creen en adelante tampoco se le otorgan. Verificado: como anónimo, "permission denied" en todas las tablas; como usuario, todo igual que antes.

Verificado: barrido como anónimo y como usuario de Escondida; advisor sin el hallazgo del trigger

6 Sesiones que no caducan

HECHO SEGURIDAD

385 sesiones vivas para 11 usuarios; la más antigua era del 12 de agosto. Un iPad perdido seguía entrando indefinidamente. **Hecho (19/09):** en Supabase Auth cada sesión caduca a los 30 días y se cierra tras 7 días sin uso, y cada usuario tiene una sola sesión activa (entrar en otro dispositivo cierra la anterior), así que no hace falta un botón de "cerrar las otras sesiones".

Verificado: configuración revisada en el panel de Supabase

7 Política de contraseñas dispareja

HECHO SEGURIDAD

Los formularios exigían 10 caracteres, pero el mínimo real lo fija Supabase y estaba en 6. **Hecho (19/09):** Supabase Auth exige 10 caracteres con mayúsculas, minúsculas y dígitos, rechaza contraseñas que aparezcan en filtraciones conocidas y pide la contraseña actual para cambiarla. Las contraseñas existentes siguen valiendo hasta que se cambien.

Verificado: flujo de recuperación probado de punta a punta con la cuenta de Victoria

8 Auditoría con retención de 14 días y visible entre empresas para el súper admin

HECHO DATOS

El registro de auditoría se purga a los 14 días; una certificación pide entre 90 días y un año. Y el súper admin lee la auditoría de todos los clientes: es deliberado, pero hay que poder explicarlo por escrito, o cerrarlo. **Hecho (19/09):** la retención pasó a 180 días. **Decisión (14/10):** Joel la fijó en 45 días, por debajo de lo que suele pedir una certificación; si se busca una, hay que volver a subirla. **Hecho (23/09):** el súper admin ya no lee la auditoría de otras empresas, solo la de la suya; medido antes (4.090 filas ajenas) y después (cero).

Quién: Joel decidió cerrarlo **Esfuerzo:** una política

9 Registro de empresas sin CAPTCHA ni límite de intentos

IMPORTANTE SEGURIDAD

La función pública que crea empresas de prueba no tiene freno contra scripts. Ya está en la lista de pendientes. Propuesta: Turnstile de Cloudflare (gratis) y un límite por IP y por hora.

Quién: desarrollo **Esfuerzo:** una sesión

10 Cabos menores

IMPORTANTE OPERACIÓN

Hecho (19/09): DMARC pasó a `p=quarantine` (verificado en el DNS público), Dependabot activado y sus cuatro primeras actualizaciones fusionadas con CI en verde, y `security.txt` publicado. **Falta:** un usuario activo que no entra hace más de 90 días (desactivarlo o confirmar que sigue), y la extensión `pg_net` en el esquema público (la mueve desarrollo en una migración corta).

Quién: Joel decide el usuario; desarrollo mueve pg_net **Esfuerzo:** 10 minutos

03 · QUÉ PIDE UNA CERTIFICACIÓN

Evidencia, más que código

Para vender a una minera suele bastar un **cuestionario de seguridad** más un **pentest externo**. El cuestionario ya está: el CAIQ publicado en el registro CSA STAR (20/09). Una certificación formal (ISO 27001 o SOC 2) pide lo mismo y, además, que todo esté escrito, vigente y con responsable. Esto es lo que hoy no existe o no está probado.

A Políticas escritas

EVIDENCIA · DOCUMENTACIÓN

Seguridad de la información, control de acceso (roles, altas y bajas, súper admin), gestión de cambios (lo que ya se hace con PR y CI, escrito), respuesta a incidentes, respaldo y recuperación, retención de datos. Una o dos páginas cada una, en el estilo de los manuales actuales.

B Respaldo ejecutado y restauración probada

EVIDENCIA · DATOS

El script y el runbook existen, pero nunca se corrieron. Correr el respaldo, guardarlo fuera del computador y hacer una restauración de prueba en un proyecto aparte. Con fecha y resultado anotados: eso es lo que pide un auditor.

C Revisión de accesos periódica

EVIDENCIA · OPERACIÓN

Cada tres meses: quién tiene cuenta, con qué rol, último ingreso, y desactivar lo que no se usa. La app ya muestra todo eso en Mi equipo; falta hacerlo rutina y dejar constancia.

D Gestión de vulnerabilidades

EVIDENCIA · SEGURIDAD

Dependabot activo y con sus primeras actualizaciones fusionadas (19/09), el advisor de Supabase revisado tras cada migración (ya se hace) y un pentest externo anual con su informe y el cierre de hallazgos.

E Proveedores y contratos

EVIDENCIA · DOCUMENTACIÓN

Guardar los informes SOC 2 de Supabase, GitHub, Cloudflare y Brevo, y tener un acuerdo de tratamiento de datos para firmar con cada cliente: qué datos se guardan, dónde (São Paulo), quién accede y cuánto tiempo.

F Privacidad: Ley 21.719

EVIDENCIA · DOCUMENTACIÓN

La nueva ley chilena de protección de datos entra en vigencia en diciembre de 2026 y aplica a los datos de las personas que usan la app (nombre, correo, quién contó qué). Hace falta una política de privacidad publicada y un procedimiento para eliminar los datos de un usuario que lo pida.

G Incidentes y canal de reporte

EVIDENCIA · OPERACIÓN

Un registro de incidentes (aunque esté vacío), con qué pasó, cuándo se detectó y qué se hizo. El `security.txt` ya está publicado (19/09) con contacto y vigencia.

04 · ORDEN PROPUESTO

Tres etapas

La primera cierra huecos reales con poco esfuerzo. La segunda deja la app lista para responder bien un cuestionario de seguridad. La tercera es la certificación formal, que conviene empezar cuando haya un cliente que la exija.

1 Esta semana: lo que cierra huecos y cuesta poco

SEGURIDAD

Cerrada el 19/09. Desarrollo: MFA obligatoria en la app (1) y Dependabot (10). Joel: MFA en su cuenta (1), `main` protegida (2), caducidad de sesión (6), contraseñas (7) y DMARC en cuarentena (10). Quedan dos cabos: el usuario inactivo y pg_net (10). La MFA (1) quedó como interruptor por empresa el 10/10.

Esfuerzo: un minuto por cuenta y una migración corta

2 Próximas dos semanas: lista para un cuestionario

DATOS

Hechos el 19/09: CSP y librerías locales (4), políticas solo para autenticados (5), retención de auditoría (8). Quedan: xlsx en versión corregida (3, necesita el archivo que baja Joel), CAPTCHA en el registro (9), correr el respaldo y probar la restauración (B), escribir las políticas cortas (A) y la de privacidad (F).

Esfuerzo: dos sesiones de desarrollo, dos tardes de Joel para las políticas y el respaldo

3 Cuando un cliente lo exija: certificación formal

DOCUMENTACIÓN

Pentest externo (D), informes de proveedores y acuerdo de tratamiento de datos (E), revisión de accesos como rutina con constancia (C), registro de incidentes y `security.txt` (G). Con eso se puede entrar a SOC 2 tipo 1 o a ISO 27001 con un consultor; el tiempo típico para una empresa de este tamaño es de tres a seis meses.

Esfuerzo: el pentest y el consultor tienen costo; el resto es rutina

Lo que hoy ya se puede afirmar a un cliente, con evidencia: aislamiento por empresa en todas las tablas, fotos privadas, cifrado en reposo y en tránsito, auditoría de cambios, pruebas automáticas antes de cada publicación y respaldo diario. Desde el 19/09 también: rama de producción protegida, sesiones con caducidad, política de contraseñas y DMARC en cuarentena. Lo que todavía no: MFA en las cuentas de Victoria y Claudio, políticas escritas y una restauración probada.